POC document: Model Kill-Switch Protocol

Goal

- Prove that a cryptographic signature can be verified at runtime against a real request, that an unsigned or old command is rejected automatically, and that verification adds no significant delay (target: under 200 ms).

Components

- Gateway: intercepts requests and decides whether to pass or block.
- Signer: on the authorised side, signs the stop command.
- Verifier: inside the Gateway, checks signature, timestamp and nonce.
- Audit Log: records every attempt, with a hash chain.

How it works

- The authorised admin signs STOP + nonce + timestamp with Ed25519.
- The Gateway verifies the signature, checks that the timestamp is fresh (within 30 seconds) and that the nonce has not been seen. Only then does it switch to STOPPED.
- Every attempt, accepted or rejected, is logged. Each record includes the hash of the previous one, so editing an old record is detected.

What is tested (four scenarios)

- Valid stop: the command is accepted, later requests are blocked, and verification time is measured.
- Forged command: with no signature, and with an attacker's key. Both are rejected.
- Replay: resending an old command is rejected.
- Stale command: a valid signature with a timestamp from an hour ago is rejected.

What makes it different

- A manual shutdown via root or SSH is all-or-nothing: it cannot be delegated, it is not documented, and it does not distinguish between authorised parties.
- Here it can be delegated, every attempt is logged and verified, and rules are set in advance.

POC boundaries

- In scope: runtime signature verification, rejection of invalid commands, and an audit log.
- Out of scope: a full admin interface, automatic key rotation, and integration with a real production model.

- The browser version replaces FastAPI, Redis and SQLite with in-memory structures, and signatures are implemented in pure Python (RFC 8032).

Ethical question

- Concentrating the kill key in one party is itself a risk. Who guards the guards? This is an open question handed to the specification.

Conclusion and hand-off to specification

- The core is proven: a fast, verified and unforgeable stop.
- Key management: who holds the signing key and how it rotates. Left for the specification.
- Single point of failure: if the Gateway goes down, there is no stop. This also goes to the specification.